

NEXUM

Security Scan Report

Generated: 2026-05-17 17:53 UTC · Source: nodoc_m365-apps-inventory.yml

60 / 100

Tier 1 — MODERATE RISK

6 findings total · 6 HIGH

Top Findings

[NEXUM-004] HIGH

/inventory/api/SecurityCurrencyGoal({goalId})
PATCH /inventory/api/SecurityCurrencyGoal({goalId}) accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

[NEXUM-004] HIGH

/inventory/api/Settings({settingsId})
PATCH /inventory/api/Settings({settingsId}) accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

[NEXUM-004] HIGH

/inventory/api/Onboarding/Onboard()
POST /inventory/api/Onboarding/Onboard() accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

Full Findings — Grouped by Rule

NEXUM-004 — IdempotencyMissing (HIGH)

Path	Method	Severity
/inventory/api/Onboarding/Onboard()	POST	HIGH
/inventory/api/Onboarding/Offboard	POST	HIGH
/inventory/api/SecurityCurrencyGoal	POST	HIGH
/inventory/api/SecurityCurrencyGoal({goalId})	PATCH	HIGH
/inventory/api/Settings	POST	HIGH
...and 1 more		

Guardrail: Add 'Idempotency-Key' as a required request header. The server must store the key and return the original response for duplicate requests received within a reasonable window.

Manual Review Required

- **model_compatibility_range:** Cannot be inferred from the spec. Depends on model capabilities, deployment context, and the desired trust level for this integration.
- **auto_detected_invariants.immutable_fields:** No readOnly properties found in component schemas. Manually list any fields that must never change after resource creation.